CloudDesk Technologies

Backup and Disaster Recovery Policy

1. Authority, scope and ownership

SYNTHETIC / DEMO - document control

CD-BDR-001 | Version 1.0 (wording revision). Proposed effective date: 2026-10-22. Planned next review: 2027-10-22. These dates are proposals, not an approved schedule. Owner and coordinator: Engineering Lead. Accountable approver: CTO; approval not recorded. Review annually and after material changes, incidents or exercises.

Status and limits

CloudDesk Technologies is a fictional 75-person B2B SaaS vendor. This model-authored policy sets proposed SYNTHETIC / DEMO requirements, not operating facts. Review_status: requires_user_review. It provides no evidence of deployed backup schedules, implemented controls, actual restore tests or successful recoveries. It makes no SLA, certification or legal compliance claim. It assumes no live contact directory, staffed recovery team or guaranteed response time.

Scope and ownership

This policy covers customer databases, tenant objects and attachments. It also covers production configuration, infrastructure definitions, scoped logs, SaaS dependencies and recovery documentation. System owners must identify authoritative data, dependencies, exclusions and recovery procedures. Platform Engineering must implement the technical controls assigned to it once approved. The Engineering Lead must coordinate inventories, tests and remediation. The CTO must approve objectives, resources and residual risk. Verify coverage for each asset before adoption; this document is not a backup inventory.

Related policy authority

Use access_control_policy.pdf for access requirements, encryption_key_management_policy.pdf (CD-ENC-001) for encryption and keys, information_security_policy.pdf (CD-ISP-001) for security governance, and incident_response_plan.pdf (CD-IRP-001) for incident response. These policies remain authoritative in their areas. Apply the recovery requirements here without weakening them. Record any conflict and have the Engineering Lead and CTO resolve it before adoption.

Backup and Disaster Recovery Policy

2. Inventory, impact assessment and proposed schedules

Backup inventory and classification

For each dataset, record the system owner, source, business purpose, tenant scope and highest applicable classification: Public, Internal, Confidential or Restricted under CD-ISP-001. Record the backup method, location/account/region, copy dependencies, key identifier/version, authorized restore role, vendor and runbook. Include coverage gaps, exclusions, deletion behavior, verification method, holds and the approval status of proposed frequency and retention. Keep secret key material and credentials out of the backup inventory.

Business impact analysis and objectives

System owners must prepare a business impact analysis (BIA) before recovery objectives are committed. Assess outage harm over time, data-loss tolerance, customer and contractual obligations, dependency failures, staffing, costs and recovery order. The Engineering Lead must review assumptions and feasibility. The CTO approves recovery time objectives (RTO) and recovery point objectives (RPO) after this assessment. RTO is the time to restore service; RPO is the tolerable loss of recent data. Both remain TBD pending BIA, business and contractual review. This policy provides no numerical targets or availability guarantees.

Proposed frequency and retention - TBD

Backup frequency and retention are TBD pending BIA/business and contractual review. Owners must propose risk-based values for each dataset, considering change rate, sensitivity, loss tolerance, recovery cost and obligations. The Engineering Lead must review them and the CTO must approve them before deployment. Record approved values and their rationale separately. No daily, weekly or other deployed schedule or fixed retention period is asserted. Assess snapshots and replication for recoverability independently: replication can propagate corruption and does not by itself prove that a backup can be recovered.

Retention, holds and disposal

Reconcile backup expiry with customer deletion commitments, legal or incident holds and vendor deletion behavior, using appropriate advice. Record delayed deletion in retained copies and prevent deleted data from being unintentionally reintroduced during restore. Restrict held copies and their keys. Dispose of them only after approved retention has ended and holds have been released; keep disposal evidence. Preserve the separate minimum 12-month retention for KMS audit logs. That minimum is not a backup retention period or a rule for all records.

Backup and Disaster Recovery Policy

3. Encryption, keys and backup protection

Encryption and grant separation

Encrypt all production backups and snapshots at rest with AES-256 and protect transfers with TLS 1.2 or TLS 1.3. Use managed KMS and backup-specific key grants separate from ordinary application access. Keep key-encryption keys non-exportable in KMS. Separate key administration from routine data access; key administrators receive no default decrypt permission. The Engineering Lead must approve grants. Use unique user accounts and multi-factor authentication for administrative access. Review permissions and key grants every quarter and revoke terminated employee access within 24 hours.

Key versions and recoverability

Rotate symmetric key-encryption keys at least every 12 months under CD-ENC-001. Rotation alone does not re-encrypt historical data. Keep older key versions under restricted access for the full lifetime of dependent retained backups, including legal or incident holds. Record KMS availability, account, region, identity and version dependencies, and verify authorized decrypt access during restore checks. Never destroy a key just because the active version has rotated. Destruction requires Engineering Lead and CTO approval, evidence that dependent retention has ended, recovery checks showing no remaining need, and a destruction record.

Compromise and emergency access

For suspected key compromise, immediately open an incident, revoke affected identity grants and disable compromised key versions where safe. Create replacement keys. Assess exposure, historical re-encryption and backup recoverability before taking destructive action. The CTO must authorize temporary emergency decrypt access, with logging and next-business-day review. Use trusted identities and recovery paths; do not reconnect compromised grants to restore data. Review KMS administrative and decrypt audit events monthly and after incidents. Retain those logs for at least 12 months in restricted encrypted storage.

Proposed isolation and immutability controls

Choose backup protections according to risk. Options include separate recovery identities and restricted permission to delete backups. Consider isolated backup accounts or separate systems that would not fail together. Provider-supported immutable copies (protected from change or deletion) or offline copies are options where justified by risk. Before adoption, the Engineering Lead must technically verify how the provider applies these protections, including retention locks, recovery access and cost. Test whether control of production would let an attacker alter backups or keys. Escalate shared failure paths and document compensating safeguards. No immutable backup, air gap, separate-region copy, geo-replication or ransomware resistance is asserted as implemented.

Backup and Disaster Recovery Policy

4. Disaster activation and safe restoration

Declaration and alternate communications

The Engineering Lead must assess disruption, affected tenants, available dependencies and likely recovery needs using CD-IRP-001 severity rules. Escalate critical service loss, destructive activity or key/backup compromise promptly to the CTO. The CTO must authorize disaster declaration, material service shutdowns, resources and material residual risk. Record the scope, rationale, time and delegated authority. Follow the incident plan for urgent reversible containment. If normal accounts or messaging are unavailable or suspect, use separately verified alternate contacts and a restricted decision log. A human reviewer must validate contacts and substitutes before adoption.

Dependency-led restoration sequence

System owners must document a dependency graph and propose a restoration sequence. First establish trusted identity, administrative access, network and KMS connectivity. Then recover validated infrastructure and configuration, restore consistent databases and objects, and reconcile queues, indexes and dependent services. Validate and reconnect in phases. This sequence is a planning aid, not a claim about deployed architecture. Before each step, confirm vendor prerequisites, clean credentials, backup availability, key versions and the recovery environment. Record recovery points and dependencies. Pause if prerequisite integrity or authorized decrypt access cannot be established.

Safe recovery after a cyber incident

Coordinate containment, evidence preservation and eradication under CD-IRP-001. Assess the compromise window and backup provenance. Select a recovery point outside known corruption and record uncertainty. Scan and restore in isolation with trusted tools and rebuilt systems. Remove persistence and replace compromised credentials. A recent or decryptable backup is not proof that it is safe. Preserve incident evidence where safe; do not overwrite originals or blindly destroy keys. The Engineering Lead verifies containment. The CTO approves material residual risk and the return of critical service.

Tenant integrity and service gates

Before reconnection, system owners must verify hashes or application-level integrity, transactional consistency, tenant boundaries, permissions, schema compatibility, deletion/hold reconciliation and representative customer workflows. Reconcile replayed events and duplicate writes without exposing one tenant to another. Record gaps, actual elapsed time and the recoverable data point. Compare these with approved objectives when available; do not promise an unapproved RTO/RPO. Define phased monitoring, rollback and stop criteria. Failed checks or returning indicators must stop release and reopen the investigation. External communications require CTO authorization and a case-specific notification assessment.

Backup and Disaster Recovery Policy

5. Restore testing, continuity exercises and dependencies

Representative quarterly encrypted restore tests

Test a representative encrypted restore at least quarterly. Record data integrity, authorized key access and the recovery outcome. Plan risk-based coverage across datasets, backup types and key versions over successive tests; this does not require restoring every backup each quarter. Use isolated environments and synthetic data where feasible. Restrict handling of any necessary customer data. Record the source/backup ID, recovery point, key version, operator authorization, checks, elapsed time, failures and limitations. Compare results with approved objectives. A test is not an SLA or proof that every system can be recovered.

Negative recovery scenarios and remediation

Exercise missing or disabled keys, denied decrypt grants, unavailable KMS or providers, corrupted or incomplete copies, inconsistent database/object recovery points, compromised credentials and cross-tenant access attempts. Responders must stop unsafe restoration, preserve evidence and escalate to the Engineering Lead and CTO. Use a validated alternative or document that recovery is not possible. Never bypass authorization or suppress failed integrity checks. Assign each finding an owner and due date, and keep retest evidence. Extracting text from this policy is not a restoration test.

Annual continuity exercises are separate

Exercise continuity scenarios at least annually and after material changes under CD-ISP-001, and coordinate incident exercises under CD-IRP-001. Cover unavailable responders, alternate communications, cloud or identity outages, vendor failure, ransomware, customer impact and decision authority. Record participants, assumptions, decisions, gaps and corrective actions. An annual tabletop does not replace a representative quarterly encrypted restore. A restore test alone does not satisfy the broader annual continuity exercise. No exercise or restoration is claimed completed.

Vendor and shared dependencies

System owners must assess cloud storage, KMS, identity, DNS, SaaS exports, support availability, regional dependencies and provider recovery/deletion limitations. Assess vendors before use. The Engineering Lead must review the assessment; the CTO must accept material residual risk. Reassess critical vendors annually and after material changes or incidents. Verify contracts, export portability, recovery responsibilities, contacts and exit dependencies. Provider replication, assurances or advertised recovery targets do not establish CloudDesk recoverability. Record inaccessible vendor data and recovery gaps in the risk register.

Backup and Disaster Recovery Policy

6. Changes, exceptions and review evidence

Change approval and risk governance

Before material changes to architecture, backup methods, retention, keys, vendors or recovery runbooks, system owners must assess the effect on coverage and recoverability. The Engineering Lead must review dependencies, validation and rollback. The CTO must approve material risk and revised objectives before adoption. Update inventories and runbooks and record validation evidence. Assess risks at least annually, before material service changes and before onboarding scoped vendors. Review open risks quarterly. The CTO must accept residual risk; escalate overdue high-impact actions.

Exceptions and emergency deviations

Before deviating, the owner must record affected assets/data, the requirement, rationale, risk, compensating safeguards, responsible owner and expiry. The Engineering Lead must assess the request and the CTO must approve or reject it. Exceptions expire within 90 days and must be reviewed monthly. Renewal requires a fresh assessment and approval. Emergency deviations require an incident record and CTO review by the next business day. CD-ENC-001 remains authoritative for encryption exceptions and destructive key approvals. This policy supplies no active exception or approval.

Expected evidence artifacts

Keep the backup inventory and coverage map. Keep the BIA and objective approvals, along with proposed and approved schedules and retention.

Keep configuration and access/grant reviews. Keep backup job outcomes and failure escalations, key-version dependency checks, restore reports and integrity results.

Keep continuity exercise findings, incident decisions and vendor assessments. Keep change and exception approvals and corrective-action closure evidence. Restrict access to records and maintain ownership, version history, approved retention and holds. No completed evidence artifacts are supplied. Preserve the minimum 12-month retention for KMS audit logs without applying that minimum to all records.

Human review and adoption gate

Before adoption, human reviewers must validate staffing, substitutes, declaration authority, inventories, proposed isolation and immutability, key access and recoverability, vendor limitations, BIA, customer contracts, notification obligations and resource feasibility. The Engineering Lead must review this policy annually and after material changes, incidents or exercises. Record reviewer feedback and CTO approval before operational adoption. Approval_status: not_recorded; review_status: requires_user_review. This is a proposed policy for a fictional company, not an approved recovery plan or compliance attestation.